

Security Advisory: Improper Authentication Leading to BLE Replay Attack in Fire-Boltt Smartwatch FB BGS001

Overview

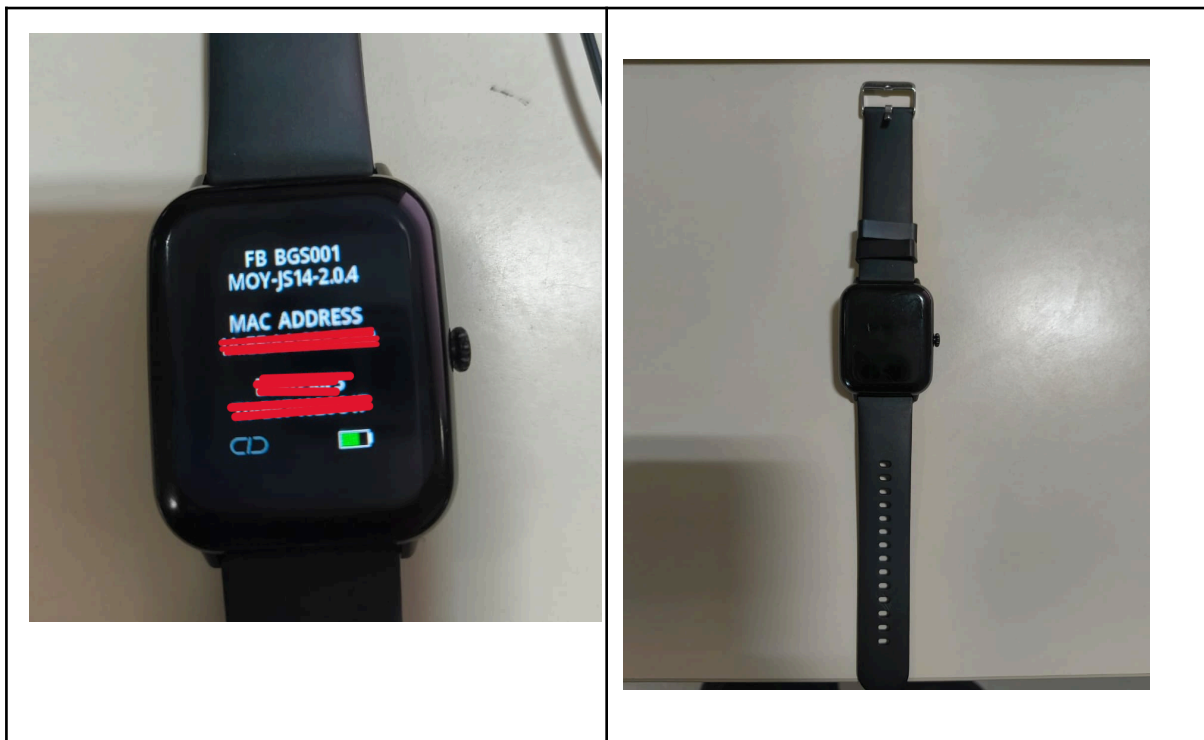
The Fire-Boltt FB BGS001 smartwatch utilizes Bluetooth Low Energy (BLE) to communicate with companion devices and support various smartwatch functions. As part of a security assessment, BLE communication was analyzed to evaluate the security of the device's authentication and session validation mechanisms.

The assessment included discovery of BLE services and characteristics, evaluation of authentication requirements, and analysis of communication exchanged between the smartwatch and the companion application.

Further testing revealed that certain GATT Write Request commands were accepted without sufficient authentication or strong session validation. Under specific conditions, previously captured BLE packets could be replayed from a nearby device, allowing authenticated functionality to be triggered without establishing a legitimate authenticated session.

This weakness may allow an attacker within Bluetooth communication range to replay captured BLE packets and trigger smartwatch functionality.

This disclosure follows responsible vulnerability disclosure practices and has been assigned **CVE-2026-37271**.



Vulnerability Summary

The assessment identified weaknesses in the authentication and session validation mechanisms implemented by the device.

Analysis of BLE communication revealed that certain GATT Write Request commands were accepted without enforcing sufficient authentication or validating the legitimacy of the active communication session.

Further evaluation demonstrated that previously captured BLE packets could be replayed under specific conditions, allowing device functionality to be triggered without proper authentication.

These weaknesses may allow unauthorized interaction with the smartwatch through replayed BLE communication.

Affected Product

Product: Fire-Boltt Smartwatch

Model: FB BGS001

Firmware Version: MOY-JS14-2.0.4

Assessment Methodology

The assessment focused on evaluating the security of Bluetooth Low Energy communication and the authentication mechanisms protecting GATT operations.

BLE communication was observed and analyzed to identify services, characteristics, and authentication requirements associated with device functionality.

Replay testing was performed to evaluate whether captured BLE communication could be reused to interact with the device.

Findings

Finding 1 – Insufficient Authentication

Analysis of BLE communication revealed that certain GATT Write Request commands were processed without sufficient authentication or strong session validation.

Observations

- Authentication requirements were not consistently enforced.
- Certain GATT Write Request commands were accepted without verifying the legitimacy of the communication session.
- Session validation mechanisms were insufficient to prevent unauthorized command processing.

Finding 2 – Replay of BLE Communication

Previously captured BLE communication was evaluated to determine whether replay protection mechanisms were present.

Observations

- Previously captured BLE packets could be replayed under specific conditions.
- Replayed packets successfully triggered smartwatch functionality.
- No effective replay protection mechanism was observed

Impact

The identified weaknesses may allow an attacker within Bluetooth communication range to replay previously captured BLE packets and interact with the smartwatch without establishing a legitimate authenticated session.

Potential Impact

- Improper Authentication
- Replay Attack
- Unauthorized Triggering of Smartwatch Functionality
- Reduced Trust in BLE Authentication Controls

```
(kali@kali)-[~/Desktop]
$ [REDACTED]
[REDACTED][LE]> connect
Attempting to connect to [REDACTED]
Connection successful
Notification handle = 0x0042 value: 00 00 00 00 00 00 00 00
Notification handle = 0x0047 value: fe ea 20 05 64
Notification handle = 0x0028 value: 60
Notification handle = 0x0028 value: 60
[REDACTED][LE]> Char-write-req 0x0045 feea2006f100
Notification handle = 0x0047 value: fe ea 20 0b f1 1a ee aa 88 c8 60
[REDACTED][LE]> Char-write-req 0x0045 feea2006f100
Notification handle = 0x0047 value: fe ea 20 0b f1 1a ee aa 88 c8 60
Notification handle = 0x0028 value: 5f
[REDACTED][LE]> Char-write-req 0x0045 feea2006f100
[REDACTED][LE]> Char-write-req 0x0045 feea2006f100
[REDACTED][LE]> █
```

Recommendations

For Vendors

- Enforce authentication for all GATT Write Request operations.
- Implement strong session validation for BLE communication.
- Introduce replay protection mechanisms such as nonces, counters, or challenge-response protocols.
- Validate packet freshness before processing BLE requests.

For Users

- Keep smartwatch firmware updated with vendor security releases.
- Pair devices only with trusted companion applications.
- Disable Bluetooth when the smartwatch is not actively in use.

Conclusion

The assessment identified weaknesses in the authentication and session validation mechanisms protecting BLE communication.

Certain GATT Write Request commands were accepted without sufficient authentication, and previously captured BLE packets could be replayed to trigger smartwatch functionality.

The vulnerability highlights the importance of implementing robust authentication and replay protection mechanisms for Bluetooth Low Energy communications.

Disclaimer

This research was conducted solely for educational and defensive security purposes.

All testing was performed in a controlled environment on authorized equipment.

The findings were responsibly disclosed prior to public release.

The information presented in this advisory is intended to promote security awareness and support remediation efforts.

Discoverers

Sarath V P

Centre for Development of Advanced Computing (C-DAC), Hyderabad